CASE STUDY

Operation Exchange Marauder and the 2021 Exchange Server Mass Exploitation

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Organizations that ran their own mail in 2021 usually ran it on Microsoft Exchange Server, an internet-facing Windows application that could not simply be switched off. In the last weeks of 2020 a researcher at the firm DEVCORE found that a single unauthenticated HTTPS request to an Exchange server could be made to act with the server's own identity, and chained that bug to a file write that put code in the web root. DEVCORE called the chain ProxyLogon and reported it to Microsoft on 5 January 2021. Two days earlier, Volexity had already seen attackers using the same server-side request forgery to pull whole mailboxes off customer servers. When Microsoft shipped out-of-band fixes on 2 March 2021, Volexity published its account under the title "Operation Exchange Marauder", and Microsoft named the operators HAFNIUM. Within days the bugs were in use by more than ten espionage groups, then ransomware crews and coin miners; by July the US government spoke of tens of thousands of compromised computers and the UK of more than a quarter of a million affected servers.

The event is worth studying for three reasons. First, the bugs that mattered were not the highest scored: three of the four were 7.8 post-authentication flaws, and most of their danger came from sitting behind a pre-authentication SSRF on port 443. Second, the patch was the start of the response, not the end: servers on unsupported cumulative updates could not take the fix, interim mitigations covered only the first link of the chain, and a patched server could still hold a web shell planted weeks earlier. Third, the same attack surface kept giving: DEVCORE's research on the same surface produced ProxyShell and ProxyOracle, a VNPT ISC researcher found the related ProxyToken bug, and ProxyShell was being used for ransomware by August 2021.

Evidence grade: the vulnerabilities, fixes, mitigations, directives and government attributions are **Confirmed** from Microsoft, CISA, NVD, DEVCORE, Volexity, ESET, Mandiant, Sophos, Talos, Symantec, the US Department of Justice and the governments that made statements. The exploit mechanics are **Demonstrated** in DEVCORE's and ZDI's technical write-ups. Victim counts relayed from press or third parties, and a few vendor timeline entries whose primary was not opened, are **Reported**. This study's own conclusions are labelled **Inferred**.

Key facts at a glance

Field	Value
Names	ProxyLogon (DEVCORE) [23]; "Operation Exchange Marauder" (Volexity's post title) [22]; operators HAFNIUM, now tracked by Microsoft as Silk Typhoon [1][11]
Product	Exchange Server 2013, 2016 and 2019 on premises; Exchange 2010 received a defense-in-depth fix; Exchange Online not affected [3]
CVEs	CVE-2021-26855 (pre-auth SSRF), CVE-2021-26857 (deserialization in Unified Messaging), CVE-2021-26858 and CVE-2021-27065 (post-auth arbitrary file write) [1]
Scores and weaknesses	26855: NVD 9.8, Microsoft 9.1, CWE-918. 26857: 7.8, CWE-502. 26858: 7.8, NVD-CWE-noinfo. 27065: 7.8, CWE-22 [57][58][59]
Found	DEVCORE, 10 to 31 December 2020 [23]
Reported to Microsoft	5 January 2021 (GMT+8) [23]
Earliest observed exploitation	3 January 2021, SSRF mailbox theft (Volexity, revised 8 March 2021) [22]
Fix	Out of band, 2 March 2021; KB5000871 for 2013, 2016 and 2019 [3][4]
Zero-day window	58 days from first observed exploitation to the fix (Inferred from [22][3])
Attribution	Microsoft: HAFNIUM, high confidence, 2 March 2021 [1]. United States: MSS-affiliated operators, "high degree of confidence" [66]; UK: Chinese state-backed actor, "almost certain" [67]; Canada: MSS, "confident" [71]; the EU and NATO did not attribute [69][70]; all 19 July 2021
Scale	Nearly 400,000 servers in scope on 1 March 2021 and a bit more than 100,000 still vulnerable on 9 March [6]; UK: over a quarter of a million servers affected worldwide [67]
CISA response	Emergency Directive 21-02, 3 March 2021; Alert AA21-062A [51][50]
Court action	FBI application to copy and delete web shells, Southern District of Texas, unsealed 13 April 2021 [63]
KEV	All four added 2021-11-03, due 2022-05-03, known ransomware campaign use: Known [57][56]
Follow-on chains	ProxyShell (CVE-2021-34473, -34523, -31207), ProxyToken (CVE-2021-33766), ProxyOracle (CVE-2021-31195, -31196) [26][28][29][25]
ATT&CK	Group G0125 HAFNIUM, aliases include Operation Exchange Marauder and Silk Typhoon; no campaign object for the event [72][80]

Key findings

- **The attackers were ahead of the disclosure.** Volexity's earliest observed SSRF mailbox theft was 3 January 2021, two days before DEVCORE reported the chain to Microsoft (Confirmed [22][23]). ESET notes that the source of the pre-patch exploit distribution remains unclear (Confirmed [31]).
- **Many groups had it before the patch.** ESET saw Tick on 28 February, LuckyMouse, Calypso and the Websiic cluster on 1 March, and the Winnti Group hours before the fix on 2 March (Confirmed [31]). Mandiant tracked three uncategorized clusters from January 2021 (Confirmed [30]).
- **Exploitation widened after the patch.** Microsoft's 5 March update recorded increased exploitation by actors beyond HAFNIUM; ESET counted more than ten APT groups and web shells on more than 5,000 servers in over 115 countries by 10 March (Confirmed [1][31]) (the causal link is Inferred).
- **Criminal follow-on came within a week.** DearCry ransomware notes surfaced around 9 March; by 18 to 20 March Black Kingdom (Microsoft's Pydomer) had placed web shells on about 1,500 systems, and Lemon Duck removed rival web shells and patched one server to keep it for itself (Confirmed [33][10]).
- **Patched did not mean clean.** Microsoft's responder guidance says the updates do not evict an adversary already on the server; Shadowserver still found 79,352 unique web shell URLs on compromised servers in its 16 to 23 March scans (Confirmed [8][44]).
- **The government went into the servers itself.** The FBI applied in federal court for remote access from on or about 9 April 2021 to copy and delete web shells on infected Exchange servers without seizing other content (Confirmed [63]); press reports say it then removed shells from hundreds of US servers (Reported [48]).
- **Attribution firmed up in July 2021 and in a 2025 indictment.** The United States named MSS-affiliated operators with a high degree of confidence; the UK said it was almost certain a Chinese state-backed actor was responsible; DOJ later charged two men it alleges acted at the direction of the Shanghai State Security Bureau (Confirmed [66][67][64]).
- **The same attack surface produced ProxyShell.** Two of its bugs were fixed in April 2021 but published only in July, the third was fixed and published in May, and ProxyShell was exploited for ransomware by August (Confirmed [13][14][52][42]); it repeated the March lesson on a shorter clock (Inferred).

Top recommendations

1. **Rank by exposure, not by score alone.** A 7.8 post-authentication bug behind a pre-authentication SSRF on an internet listener is a pre-authentication RCE. Track chains, not single CVEs (Inferred from [1][50]).
2. **Stay on a supported cumulative update.** The March fixes installed only on specific CUs, and Microsoft later tied its Emergency Mitigation service to that lesson (Confirmed [5][19]).
3. **Run two clocks.** Measure time to mitigate (URL rewrite, EOMT, the Defender auto-mitigation) separately from time to remediate (the security update), and do not close a ticket on the first (Inferred from [7][9]).
4. **Assume compromise for anything exploited before the patch.** CISA told defenders to look back to at least 1 January 2021 and to assume identity compromise if exploited (Confirmed [50]). Run the hunt even on patched servers (Confirmed [8]).
5. **Count hostnames as well as IPs.** Shadowserver's 86,138 vulnerable IPs mapped to 101,045 hostnames (Confirmed [44]); an IP-only inventory undercounts (Inferred).

6. **Plan for end of life.** Exchange 2016 and 2019 left support on 14 October 2025, and CISA's ED 25-02 required disconnecting servers not eligible for a 2025 hotfix (Confirmed [20][55]).

Scope and method

This study covers the ProxyLogon chain and its exploitation from the first observed use in January 2021 through the July 2021 attributions and the 2025 and 2026 court record, together with the follow-on Exchange chains of 2021 (ProxyShell, ProxyToken, ProxyOracle) that came from the same research and the same attack surface. The SolarWinds intrusions are a separate event: Microsoft states the HAFNIUM Exchange activity is in no way connected to them (Confirmed [2]), and the APT29 use of an older Exchange Control Panel bug (CVE-2020-0688) belongs in the SolarWinds and SUNBURST study. APT41 and the Winnti cluster get one paragraph here; their home is the APT41 public record study.

Every source was opened on 3 November 2026. Facts come from the organization that first published them, linked to the exact page. Figures are given as the source states them, with a note when the figure is a floor, an estimate, or a third party's count. Each claim carries a grade:

Grade	Meaning
Confirmed	The primary source was opened and states the fact
Reported	Only a secondary source (press, or a vendor relaying another party) states it
Demonstrated	A public reproduction or technical write-up shows it works
Inferred	This study's own reasoning from the cited record, labelled as such

Source numbers in square brackets refer to the Sources table at the end.

Part 1: the technical record

How ProxyLogon worked

In Exchange 2013 and later, the Client Access Service front end proxies requests to the mailbox back end and authenticates itself with a Kerberos ticket for the Exchange machine account. CVE-2021-26855 abused the `X-AnonResource-Backend` cookie in `OwaResourceProxyRequestHandler`, so an attacker-chosen request reached the back end carrying Exchange's own authentication (Demonstrated [24]). Microsoft describes the bug as a server-side request forgery that lets an attacker send arbitrary HTTP requests and authenticate as the Exchange server (Confirmed [1]).

From there the chain branched. Through the SSRF the attacker obtained an Exchange Control Panel session via `/ecp/proxyLogon.ecp`, then used CVE-2021-27065 to abuse the ECP `WriteFileActivity` path behind the reset of the offline address book virtual directory and write a file into the web root (Demonstrated [24]). CVE-2021-26858 is a second post-authentication arbitrary file write, and both file-write bugs are reachable either through CVE-2021-26855 or with stolen administrator credentials (Confirmed [1]). CVE-2021-26857, insecure deserialization in the Unified Messaging service, gives code execution as SYSTEM but needs administrator permission or another bug first (Confirmed [1]).

CISA summarizes the chain in one line: CVE-2021-26855 to authenticate, then CVE-2021-26858 or CVE-2021-27065 to write files anywhere, or CVE-2021-26857 to run code as SYSTEM, followed by persistence, mailbox and credential access and possible download of the Active Directory database (Confirmed [50]).

The SSRF alone was enough for espionage. Volexity saw it used without authentication to download the full contents of several user mailboxes; against a single server the attacker needed the domain SID, and against a database availability group only an email address (Confirmed [22]). Because the mail was read through Exchange Web Services with the server's own identity, the theft bypassed two-factor authentication (Confirmed [22]).

Microsoft's FAQ notes the initial attack needs an untrusted connection to port 443, and that restricting it protects only the first step of the chain (Confirmed [4]).

What was affected and what fixed it

Item	Detail	Source
Affected	Exchange Server 2013, 2016, 2019; the attack-chain code did not exist before 2013, so 2003 and 2007 were not believed affected; Exchange Online not affected	[3]
March 2021 update	KB5000871 for 2013, 2016 and 2019; Exchange 2010 SP3 received KB5000978 for CVE-2021-26857 only, as defense in depth	[3]
Supported CUs on 2 March	2013 CU23; 2016 CU18 and CU19; 2019 CU7 and CU8	[5]
Fixed builds	2013 CU23 15.00.1497.012; 2016 CU18 15.01.2106.013; 2016 CU19 15.01.2176.009; 2019 CU7 15.02.0721.013; 2019 CU8 15.02.0792.010; 2010 SP3 14.03.0513.000; 2013 SP1 15.00.0847.064	[4]
Older CUs	From 8 March, further releases 10, 11 and 16 March (the last for 2013 SP1): SUs for 2019 RTM and CU1 to CU6, 2016 CU8 to CU17, 2013 CU21, CU22 and SP1, covering only the four CVEs	[4][3]
New CUs	2016 CU20 and 2019 CU9 shipped with the fixes on 16 March 2021	[5]
Same-day, unrelated	CVE-2021-26412, CVE-2021-26854 and CVE-2021-27078 were fixed the same day and not tied to the attacks	[3]
MSRC flags	Severity Critical; exploited Yes; publicly disclosed No	[4]

Interim mitigations

Microsoft shipped a sequence of stopgaps for organizations that could not patch at once (Confirmed [3][7][9][21]):

- **Exchange On-premises Mitigation Tool (EOMT), 15 March 2021.** A one-click script that applies a URL Rewrite mitigation for CVE-2021-26855, runs the Microsoft Safety Scanner and tries to reverse changes made by detected threats. Microsoft aimed it at customers without dedicated security or IT teams and said it is not a replacement for the update [7].
- **Microsoft Defender Antivirus automatic mitigation, 18 March 2021.** Defender and System Center Endpoint Protection with security intelligence build 1.333.747.0 or newer automatically mitigate CVE-2021-26855 on vulnerable servers, with no action needed for customers on default automatic

updates [9].

- **Scripts.** The Health Checker, MSERT and the CSS-Exchange scripts, including `Test-ProxyLogon.ps1` (formerly Test-Hafnium), which automates the four log checks. In the CSS-Exchange Security folder today, EOMT is still current, `ExchangeMitigations.ps1` is obsolete (final version 22.03.03.2154), and the CVE-2021-26855 nmap script is obsolete [3][21].

Both EOMT and the Defender mitigation cover only the first link. A server that already holds a web shell, or an attacker with administrator credentials using CVE-2021-26858 or CVE-2021-27065 directly, is not stopped by the URL rewrite (Inferred from [1][7][9]).

The same attack surface, three more times

DEVCORE's own tally counts eight vulnerabilities on this attack surface, chained into ProxyLogon, ProxyOracle and ProxyShell, and its survey counted more than 400,000 internet-facing Exchange servers (Confirmed [26]).

ProxyShell. Orange Tsai of DEVCORE demonstrated the chain at Pwn2Own Vancouver on 6 April 2021, earning $200,000 and 20 Master of Pwn points (Demonstrated [27]); the bugs were reported to ZDI on 2 April (Confirmed [28]). CVE-2021-34473 is a pre-authentication path confusion in Explicit Logon handling reached through an `autodiscover.json` URL; CVE-2021-34523 lets the Exchange PowerShell back end take its identity from the `X-Rps-CAT` parameter; CVE-2021-31207 writes a web shell through `New-MailboxExportRequest` with a PST-encoded payload (Demonstrated [28]). CVE-2021-34473 and CVE-2021-34523 were fixed in the April 2021 update KB5001779, but MSRC published them only on 13 July 2021, noting they were "inadvertently omitted" from the April notes (Confirmed [13]). CVE-2021-31207 was released on 11 May 2021 in KB5003435, rated Moderate with impact Defense in Depth (Confirmed [14]). The April update also covered 2013 CU23, 2016 CU19 and CU20, and 2019 CU8 and CU9; at the time Microsoft said it was not aware of active exploits and that the bugs came from a security partner (Confirmed [12]). The same April release fixed CVE-2021-28480 to CVE-2021-28483, credited to the NSA (Reported [45]).

ProxyShell fixed builds	April 2021, KB5001779	May 2021, KB5003435
2013 CU23	15.00.1497.015	15.00.1497.018
2016 CU19	15.01.2176.012	15.01.2176.014
2016 CU20	15.01.2242.008	15.01.2242.010
2019 CU8	15.02.0792.013	15.02.0792.015
2019 CU9	15.02.0858.010	15.02.0858.012

Source: MSRC [13] (Confirmed).

ProxyToken. CVE-2021-33766 (ZDI-21-798) was found by Le Xuan Tuyen of VNPT ISC and reported in March 2021. Requests to `/ecp` with a non-empty `SecurityToken` cookie skip authentication because the back end's `DelegatedAuthModule` is not loaded, which let an attacker set a forwarding rule on any mailbox (Demonstrated [29]). MSRC published it on 13 July 2021 listing the April KB5001779 as the fix, with the same inadvertently-omitted note and impact Information Disclosure (Confirmed [15]); ZDI's write-up instead says it was "patched by Microsoft in the July 2021 Exchange cumulative updates" (Confirmed [29]).

ProxyOracle. CVE-2021-31195, a reflected XSS, plus CVE-2021-31196, a padding oracle on the forms-based authentication `cadata` cookie, recover a user's plaintext password after one click; DEVCORE reported them on 17 January 2021 (Demonstrated [25]). MSRC fixed CVE-2021-31195 in May 2021 (KB5003435, impact Spoofing) and CVE-2021-31196 in July 2021 in KB5004778 (2013 CU23 15.00.1497.023), KB5004779 (2016 CU20 15.01.2242.012, CU21 15.01.2308.014) and KB5004780 (2019 CU9 15.02.0858.015, CU10 15.02.0922.013) (Confirmed [16]).

Scores and catalogs

CVE	Chain	NVD CVSS 3.1 (CNA)	NVD CWE	KEV added	KEV due	Source
CVE-2021-26855	ProxyLogon	9.8 (Microsoft 9.1)	CWE-918	2021-11-03	2022-05-03	[57]
CVE-2021-26857	ProxyLogon	7.8	CWE-502	2021-11-03	2022-05-03	[58]
CVE-2021-26858	ProxyLogon	7.8	NVD-CWE-noinfo	2021-11-03	2022-05-03	[58]
CVE-2021-27065	ProxyLogon	7.8	CWE-22	2021-11-03	2022-05-03	[58][59]
CVE-2021-34473	ProxyShell	9.8 (9.1)	CWE-918	2021-11-03	2021-11-17	[60]
CVE-2021-34523	ProxyShell	9.8 (9.0)	NVD-CWE-noinfo	2021-11-03	2021-11-17	[60]
CVE-2021-31207	ProxyShell	6.6	CWE-434	2021-11-03	2021-11-17	[60]
CVE-2021-33766	ProxyToken	7.5 (7.3)	NVD-CWE-noinfo	2022-01-18	2022-02-01	[61]
CVE-2021-31195	ProxyOracle	8.8 (6.5; CNA CWE-290)		not in KEV		[62]
CVE-2021-31196	ProxyOracle	7.2	NVD-CWE-noinfo	2024-08-21	2024-09-11	[62]

All four ProxyLogon CVEs and the ProxyShell trio carry known ransomware campaign use "Known" in the KEV feed, which lists 18 Exchange Server entries as of catalog version 2026.11.03 (Confirmed [56]). NVD published the four ProxyLogon records on 3 March 2021 (Confirmed [57][58]).

Discrepancies in the record

- **The KEV date is not an exploitation date.** The 2021-11-03 add date is the catalog's launch batch under BOD 22-01, eight months after the attacks (Inferred from [57][56]).
- **Two patch dates.** DEVCORE dates the fix 3 March 2021 because it works in GMT+8; Microsoft and Volexity date it 2 March (Inferred from [23][3][22]).
- **The patch came early.** MSRC told DEVCORE on 18 February 2021 that the fix would ship on 9 March, March's Patch Tuesday, and on 27 February that the release was nearly ready; it shipped out of band on 2 March (Confirmed [23]; MSRC's side of the exchange not seen).
- **Volexity's first date moved.** Its 8 March update moved the earliest SSRF mailbox theft from 6 January to 3 January 2021 (Confirmed [22]).
- **Credit.** Orange Tsai's Black Hat USA 2021 credit table attributes ProxyLogon to DEVCORE and credits Dubex and MSTIC for CVE-2021-26857 (Confirmed [26]).
- **Silent fixes.** Three CVEs fixed in April 2021 (34473, 34523, 33766) were published only in July (Confirmed [13][15]).
- **ED 21-02 version labels.** CISA's closed ED 21-02 page labels the forensic-triage direction V2 (13 April) although its first deadline is 5 April, and labels the April-update direction V1 (31 March) although those

updates shipped on 13 April; this study gives the deadlines as the page states them and does not settle which version carried which (Inferred from [51]).

Part 2: the timeline

Date	Event	Grade	Source
2020-10-01	DEVCORE begins reviewing Exchange Server security	Confirmed	[23]
2020-12-10	DEVCORE finds the pre-auth proxy bug, later CVE-2021-26855	Confirmed	[23]
2020-12-27	DEVCORE escalates it to an administrator authentication bypass	Confirmed	[23]
2020-12-30	DEVCORE finds the post-auth file write, later CVE-2021-27065	Confirmed	[23]
2020-12-31	DEVCORE has a working pre-auth RCE chain	Confirmed	[23]
2021-01-03	Earliest SSRF mailbox theft Volexity observed (revised from 6 January)	Confirmed	[22]
2021-01-05	DEVCORE submits its advisory and exploit to MSRC (GMT+8)	Confirmed	[23]
2021-01-06	MSRC acknowledges; confirms the behaviour on 8 January	Confirmed	[23]
January 2021	Mandiant sees Exchange abuse at a client: `help.aspx` written by `UMWorkerProcess.exe`, `iisstart.aspx` about 20 days later	Confirmed	[30]
2021-01-17	DEVCORE reports the ProxyOracle bugs	Confirmed	[25]
2021-01-18	Dubex observes `UMWorkerProcess` exploitation (CVE-2021-26857), notifies Microsoft on 27 January	Reported (via Unit 42; Dubex primary not found)	[32]
2021-01-30	DOJ alleges Xu Zewei confirmed a second Texas university compromise to Zhang Yu on or about this date	Confirmed (allegation)	[64]
2021-02-02	Volexity reports its activity to Microsoft (per Unit 42; Volexity's post gives no date)	Reported	[32]
2021-02-18	MSRC tells DEVCORE the patch date is 9 March	Confirmed	[23]
2021-02-27	Unit 42 reports web shell activity rising, with multiple groups over the next two days; MSRC tells DEVCORE the release is nearly ready	Reported; Confirmed	[32][23]
2021-02-28	ESET sees Tick exploiting Exchange; DOJ alleges Xu updated an SSSB officer on or about this date	Confirmed; Confirmed (allegation)	[31][64]
late February 2021	DEVCORE says HAFNIUM used the exploit in late February, citing Unit 42, Rapid7 and CrowdStrike	Reported	[23]
2021-02-27 to 2021-03-03	Red Canary's random-eight-character China Chopper cluster	Confirmed	[35]

Date	Event	Grade	Source
2021-03-01	ESET sees LuckyMouse, Calypso and Websiic; RiskIQ counts nearly 400,000 Exchange servers in scope	Confirmed	[31][6]
2021-03-02	Microsoft ships out-of-band fixes and attributes to HAFNIUM; Volexity publishes "Operation Exchange Marauder"; ESET sees the Winnti Group hours before the patch	Confirmed	[3][1][22][31]
2021-03-03	CISA issues ED 21-02 and Alert AA21-062A; NVD publishes the four CVEs; ESET sees Tonto Team, ShadowPad activity, the "Opera" Cobalt Strike cluster (from 04:23 UTC, about 650 servers) and IIS backdoors	Confirmed	[51][50][57][31]
2021-03-04	DEVCORE confirms the in-the-wild exploit matches its report; Mandiant publishes UNC2639, UNC2640 and UNC2643; ESET sees Mikroceen	Confirmed	[23][30][31]
2021-03-05	Microsoft notes exploitation by multiple actors beyond HAFNIUM; ESET sees DLTMiner from 02:53 UTC; Red Canary notices Sapphire Pigeon; KrebsOnSecurity reports at least 30,000 US organizations newly hacked	Confirmed; Confirmed; Confirmed; Reported	[1][31][35][46]
2021-03-08	Expanse counts over 125,000 unpatched servers (via Unit 42); MSRC begins shipping SUs for older CUs	Reported (via Unit 42); Confirmed	[32][3]
2021-03-09	A bit more than 100,000 servers still vulnerable (Microsoft citing RiskIQ); first DearCry ransom notes surface	Confirmed	[6][33]
2021-03-10	ESET: more than ten APT groups, web shells on more than 5,000 servers in over 115 countries	Confirmed	[31]
2021-03-11	Microsoft has released updates covering more than 95% of exposed versions; BleepingComputer reports DearCry, detected by Microsoft as DoejoCrypt	Confirmed; Reported	[6][47]
2021-03-12 to 13	AA21-062A adds DearCry (12 March) and seven China Chopper MARs (13 March); Sophos blocks the first DearCry attack in Austria on 13 March	Confirmed	[50][36]
2021-03-15	Microsoft releases EOMT	Confirmed	[7]
2021-03-16	Responder guidance; final older-CU SU for 2013 SP1; 2016 CU20 and 2019 CU9 ship with the fixes	Confirmed	[8][3][5]
2021-03-16 to 23	Shadowserver: 86,138 IPs and 101,045 hostnames still vulnerable; 79,352 web shell URLs	Confirmed	[44]
2021-03-18	Defender automatic mitigation; Sophos first detects Black Kingdom	Confirmed	[9][37]

Date	Event	Grade	Source
2021-03-18 to 20	Pydomer (Black Kingdom) web shells placed on about 1,500 systems	Confirmed	[10]
2021-03-23	Rapid7 details post-exploitation discovery through China Chopper	Confirmed	[34]
2021-03-25	Microsoft: more than 92% of known Exchange IPs patched or mitigated; details DoejoCrypt, Pydomer, Lemon Duck and miners	Confirmed	[10]
2021-03-31	ED 21-02 Supplemental Direction V1 issued (see Discrepancies)	Confirmed	[51]
2021-04-02	Orange Tsai reports the ProxyShell bugs through ZDI	Confirmed	[28]
2021-04-06	ProxyShell demonstrated at Pwn2Own Vancouver	Demonstrated	[27]
2021-04-09	Start of the 14 days of remote access the FBI sought to copy and delete web shells	Confirmed	[63]
2021-04-12	CISA MAR-10330097-1.v1 on DearCry	Confirmed	[50]
2021-04-13	April SUs (KB5001779) fix 34473, 34523, 33766 and CVE-2021-28480 to -28483; ED 21-02 Supplemental Direction V2; the FBI filing is unsealed	Confirmed; Reported [45]	[12][45][51][63]
2021-05-11	May SUs fix CVE-2021-31207 and CVE-2021-31195	Confirmed	[14][16]
2021-05-15	Sophos describes an Epsilon Red victim paying 4.29 BTC, hedging on whether ProxyLogon was the entry point	Confirmed	[38]
2021-07-13	MSRC publishes 34473, 34523 and 33766 as fixed in April; July SUs fix CVE-2021-31196	Confirmed	[13][15][16]
2021-07-19	US, UK, EU, NATO and Canada statements on the Exchange compromise; NSA, CISA and FBI publish AA21-200B; AA21-062A updated with the MSS attribution	Confirmed	[66][67][69][70][71][53][50]
2021-07-20	Symantec first sees LockFile at a US financial organization; China's foreign ministry rejects the attribution	Confirmed; Reported	[42][49]
2021-07-22	Exchange team describes AMSI integration in the June 2021 CUs	Confirmed	[18]
2021-08-06	DEVCORE publishes ProxyLogon technique details	Confirmed	[23][24]
2021-08-13	Kevin Beaumont reportedly first sees ProxyShell exploitation (cited by Symantec)	Reported	[42]
2021-08-17	ZDI publishes the ProxyShell write-up	Demonstrated	[28]

Date	Event	Grade	Source
2021-08-18 to 25	Huntress: over 100 ProxyShell incident reports, 1,764 of about 1,900 servers unpatched (22 August), over 200 hidden web shells across 4,000+ servers (25 August)	Confirmed	[43]
2021-08-20	Symantec ties LockFile to ProxyShell-era Exchange access	Confirmed	[42]
2021-08-21	CISA urgent alert on active ProxyShell exploitation	Confirmed	[52]
2021-08-25	Exchange team: May or July SUs protect; EOMT alone or old CUs do not	Confirmed	[17]
2021-08-30	ZDI publishes ProxyToken	Demonstrated	[29]
early September 2021	Sophos: Conti affiliate enters through ProxyShell, ransomware on day five	Confirmed	[39]
2021-09-24	Exchange Emergency Mitigation service announced for the September 2021 CU	Confirmed	[19]
October 2021	Iranian government-sponsored actors exploiting CVE-2021-34473 since at least this month	Confirmed	[54]
2021-10-12	Talos first sees the Tortilla actor delivering Babuk, likely through ProxyShell	Confirmed	[41]
2021-11-03	KEV launches with the seven ProxyLogon and ProxyShell CVEs	Confirmed	[56]
2021-11-17	FBI, CISA, ACSC and NCSC publish AA21-321A	Confirmed	[54]
2022-01-18	ProxyToken added to KEV	Confirmed	[61]
2024-08-21	CVE-2021-31196 added to KEV	Confirmed	[62]
2025-03-05	Microsoft's Silk Typhoon report says it began seeing the group exploit Exchange zero-days in January 2021	Confirmed	[11]
2025-07-03	Xu Zewei arrested in Milan; DOJ announces charges on 8 July	Confirmed	[64]
2025-08-07	CISA ED 25-02 on an Exchange hybrid vulnerability	Confirmed	[55]
2025-10-14	Exchange 2016 and 2019 leave support	Confirmed	[20]
2026-01-08	ED 21-02 closed, actions moved to BOD 22-01	Confirmed	[51]
2026-04-27	Xu Zewei, extradited from Italy, appears in US District Court in Houston	Confirmed	[65]

Part 3: who exploited it

HAFNIUM

Microsoft attributes the campaign with high confidence to HAFNIUM, a group it assesses as state-sponsored and operating from China, on the basis of victimology, tactics and procedures (Confirmed [1]). HAFNIUM operates mainly from leased virtual private servers in the United States and targets US infectious disease researchers, law firms, higher education, defense contractors, policy think tanks and NGOs (Confirmed [1]). After exploitation, Microsoft saw ASPX web shells, Procdump against LSASS, 7-Zip staging, Exchange PowerShell snap-ins exporting mailboxes, Nishang `Invoke-PowerShellTcpOneLine`, PowerCat, Covenant command and control, and download of the offline address book (Confirmed [1]). Microsoft describes exfiltration to file-sharing sites such as MEGA as HAFNIUM's usual pattern, not as something observed in these intrusions (Confirmed [1]).

Volexity's account, which gives the event its "Operation Exchange Marauder" name only in the title, makes no named attribution and describes highly skilled attackers with multiple operators doing cyber espionage (Confirmed [22]). It found ASPX web shells in every RCE case: the SIMPLESEESHARP dropper, SPORTSBALL, China Chopper variants, ASPXSPY, code injected into legitimate ASPX files, and PHP shells (Confirmed [22]). Its post-exploitation list adds `rundll32 comsvcs.dll MiniDump` against lsass, ProcDump, PsExec lateral movement, WinRAR archiving, new domain accounts, NTDS.DIT copies, and web shells used for proxying, from 13 attacker IPs on VPS and VPN services (Confirmed [22]). Rapid7's post-exploitation analysis of China Chopper sessions, which it did not tie to a named actor in the record checked here and which ATT&CK cites on G0125, shows the discovery that followed: `whoami`, `tasklist`, `nltest /dclist`, `net group "Domain Computers"`, `curl` to ipinfo.io, pings to 8.8.8.8, and `attrib` to hide web shells (Confirmed [34]).

Microsoft now tracks HAFNIUM as Silk Typhoon and says it began observing the group exploiting Exchange zero-days in January 2021, without a confidence statement (Confirmed [11]). ATT&CK's G0125 entry describes a likely state-sponsored cyber espionage group operating out of China, active since at least January 2021, a more hedged wording than Microsoft's (Confirmed [72]). Rows on G0125 that cite only the 2025 Silk Typhoon, 2022 Tarrask or December 2021 Log4j sources are not the 2021 Exchange event (Confirmed [72]); the Log4j activity is covered in the Log4Shell study.

The espionage crowd before and after the patch

ESET identified more than ten threat actors that likely used the Exchange RCE and warned that some may have hijacked other actors' web shells (Confirmed [31]).

Actor or cluster (ESET name)	First seen	Targets and tooling	ATT&CK object	Source
Tick	2021-02-28	East Asian IT services web server; Delphi backdoor; likely had the exploit before the patch	G0060 BRONZE BUTLER, whose page has no Exchange 2021 row	[31][74]
LuckyMouse (APT27)	2021-03-01	Middle East government mail server; NBTscan, a reGeorg variant, attempted SysUpdate	G0027 Threat Group-3390; ATT&CK's T1190 row names the four CVEs, citing Trend Micro (not opened)	[31][75]

Actor or cluster (ESET name)	First seen	Targets and tooling	ATT&CK object	Source
Calypso	2021-03-01	Government mail servers in the Middle East and South America, later Africa, Asia and Europe; PlugX via DLL search-order hijacking; a Mimikatz variant	No ATT&CK group object	[31]
Websiic	2021-03-01	Private-company mail servers in Asia, one Eastern European government body; not tied to a known actor	None	[31]
Winnti Group	2021-03-02, hours before the patch	East Asian oil company and construction equipment company; web shells, PlugX, a Winnti loader, Mimikatz	G0044 Winnti Group, whose page has no Exchange 2021 row; ESET's alias also points at G0096 APT41	[31][74]
Tonto Team (CactusPete)	2021-03-03	Eastern European procurement and consulting firms; ShadowPad, a Bisonal variant, an LSASS dumper	G0131 Tonto Team, four rows citing ESET	[31][73]
Unattributed ShadowPad	2021-03-03	East Asian software firm, Middle East real estate firm	None	[31]
"Opera" Cobalt Strike	2021-03-03 04:23 UTC	About 650 servers, mostly US, Germany, UK and other Europe; trojanized Opera executable	None	[31]
IIS backdoors	2021-03-03	Modified IIS-Raid and an Owlproxy variant on four mail servers in Asia and South America	None	[31]
Mikroceen (Vicious Panda)	2021-03-04	Central Asian utility; first steps not tied to Mikroceen with high confidence	None	[31]
DLTMiner	2021-03-05 02:53 UTC	PowerShell downloaders, possibly through hijacked web shells	None	[31]

ATT&CK records the Exchange zero-days on the APT41 group page as a T1190 row naming CVE-2021-26855 (Confirmed [75]). The Winnti and APT41 cluster's full record, including how ATT&CK separates G0044 from G0096, is in the APT41 public record study; ESET's Winnti sighting must not be mapped to G0044's ATT&CK page, which carries no Exchange 2021 row (Confirmed [74]).

Mandiant tracked three uncategorized clusters, UNC2639, UNC2640 and UNC2643, from January 2021, with China Chopper and Cobalt Strike BEACON under UNC2643; victims included US retailers, local governments, a university and an engineering firm, and Mandiant made no formal attribution (Confirmed [30]). Red Canary described a random-eight-character China Chopper cluster (27 February to at least 3 March) and Sapphire Pigeon (noticed 5 March, scheduled task `Winnet`), and said none of its clusters overlapped significantly with HAFNIUM (Confirmed [35], read on the copy the Red Canary URL now redirects to).

Ransomware and miners

Family	What the record shows	Source
DearCry (Microsoft: DoejoCrypt)	Microsoft calls it the first ransomware seen exploiting the bugs: a Chopper web shell drops a batch file that copies SAM and registry hives, then Cobalt Strike, then encryption with `.CRYPT`, sometimes in under 30 minutes; actors with Domain Admin ran `ntdsutil` (Confirmed). Sophos blocked its first attack in Austria on 13 March after a web shell landed on 11 March; AES-256 plus RSA, no C2 needed; a header resembling WannaCry without tying it to WannaCry's author; likely a beginner or an early prototype (Confirmed). Unit 42 dates the first ransom notes around 9 March (Confirmed)	[10][36][33]
Black Kingdom (Microsoft: Pydomer)	Sophos first detected it on 18 March; it exploited CVE-2021-27065, dropped `ChackLogsPL.aspx` through `w3wp.exe`, and was rudimentary, with Tor exit-node delivery (Confirmed). Microsoft calls Pydomer the first existing ransomware family to use the bugs (it had used Pulse Secure flaws before), with web shells on about 1,500 systems mainly 18 to 20 March, and some victims receiving an extortion note without encryption (Confirmed). Both drop `decrypt_file.TxT`, use "Chack" web shell names and are Python-based, so they are very likely the same family, though neither source says so (Inferred)	[37][10]
Lemon Duck	Fileless PowerShell from the IIS worker, Defender real-time monitoring disabled, scheduled task and WMI persistence, Ramnit and other payloads, mail from compromised mailboxes; it removed rival web shells and patched CVE-2021-26855 on one server to keep exclusive access (Confirmed). Talos saw Exchange-linked Lemon Duck and DLTMiner infrastructure from early March with Cobalt Strike DNS beacons, `wanlin.aspx` shells, `attrib` hiding, XMRig, a local user named `netcat` and RDP enabled, and assesses with medium confidence these are newer Lemon Duck components	[10][40]
XMRig miners	Several mining campaigns added Exchange, mostly XMRig	[10]
Epsilon Red	Sophos describes a victim paying 4.29 BTC on 15 May 2021 and hedges on whether ProxyLogon was the entry point	[38]

CISA's KEV feed marks all four ProxyLogon CVEs with known ransomware campaign use (Confirmed [56]). The White House statement of July 2021 adds that the PRC uses criminal contract hackers who run unsanctioned operations including ransomware, extortion and crypto-jacking (Confirmed [66]); it does not tie any named ransomware family above to those contractors, and this study does not either (Inferred).

ProxyShell exploitation

Actor	What the record shows	Source
LockFile	Symantec first saw it on 20 July 2021 at a US financial organization; its 20 August report ties it to ProxyShell-era Exchange access, PetitPotam, a KuGou DLL hijack and KDU	[42]
Unknown	CISA's 21 August alert: malicious actors actively exploiting the three ProxyShell CVEs; apply the May 2021 SU immediately (the alert does not mention LockFile)	[52]
Conti affiliate	Sophos: entry through ProxyShell in early September 2021, domain admin in about four hours, just under 1 TB exfiltrated to MEGA, ransomware on day five	[39]
Tortilla (Babuk)	Talos first saw it on 12 October 2021, moderate confidence it exploited ProxyShell, active since July 2021	[41]
Iranian government-sponsored actors	FBI, CISA, ACSC and NCSC: exploiting CVE-2021-34473 since at least October 2021 for initial access; the advisory names no ATT&CK group	[54]
Later ATT&CK rows	G1022 ToddyCat (ProxyLogon, citing Kaspersky 2022), G0059 Magic Hound (ProxyShell), G0046 FIN7 (CVE-2021-31207), G1043 BlackByte (ProxyLogon and ProxyShell), G1003 Ember Bear (ProxyShell)	[75]

Huntress, working from its own customer base, found 1,764 of about 1,900 servers still unpatched on 22 August and more than 200 hidden web shells across more than 4,000 servers by 25 August (Confirmed [43]). The Exchange team warned on 25 August that servers on old unsupported CUs, on the March older-CU SUs, or protected only by EOMT were not protected, and that unpatched servers might be used to deploy ransomware (Confirmed [17]).

Part 4: attribution and the government record

From vendor to governments

Microsoft named HAFNIUM on day one, with high confidence (Confirmed [1]). Volexity named no one (Confirmed [22]). Four and a half months later, on 19 July 2021, governments spoke in a coordinated set of statements:

Party	What it said about Exchange	Confidence language	Source
United States (White House)	MSS-affiliated cyber operators conducted the espionage using the Exchange zero-days disclosed in early March 2021; tens of thousands of computers were compromised before patches	"high degree of confidence"	[66]
United Kingdom (FCDO citing NCSC)	A Chinese state-backed threat actor initiated and exploited the compromise; HAFNIUM is highly likely associated with the Chinese state; over a quarter of a million servers affected; NCSC advised over 70 affected organisations	"almost certain"; "highly likely"	[67]

Party	What it said about Exchange	Confidence language	Source
NCSC	Cites public reporting of at least 30,000 organisations compromised in the US alone; highly likely to enable large-scale espionage	"highly likely"	[68]
European Union (High Representative)	The Exchange compromise has its own paragraph and allowed access to a significant number of hackers; it is not tied to APT40 or APT31 and not attributed to the Chinese government	No attribution	[69]
NATO	Solidarity with those affected; acknowledges national attributions by Canada, the UK and the US	No attribution of its own	[70]
Canada	Confident the MSS is responsible for the widespread Exchange compromise	"confident"	[71]
NSA, CISA, FBI (AA21-200B)	PRC state-sponsored TTPs, including scanning and exploiting Exchange OWA from short-term VPS and planting web shells	Assessed major threat	[53]
China (foreign ministry)	Rejected the attribution, called the US the world's largest source of cyberattacks, asked the US and allies to withdraw the accusations	Denial	[49] (Reported; MFA transcript not opened)

The confidence ladder runs from the vendor's "high confidence" for HAFNIUM, to the governments' "high degree of confidence", "almost certain" and "confident" for state responsibility, to ATT&CK's "likely state-sponsored", to the DOJ charging document's allegation of direction by named officers. The EU and NATO stop short of naming the Chinese state for Exchange, and only the UK names HAFNIUM (Inferred from [1][66][67][69][70][71][72][64]).

The same day's statements attributed other activity to APT40 and APT31. The UK linked APT40 to the MSS (highly likely) and called APT31 affiliated to the state (almost certain); Canada said APT40 almost certainly includes elements of the Hainan State Security Department (Confirmed [67][71]). Those are separate attributions, and this study does not fuse APT40 or APT31 with the Exchange campaign (Inferred from [67][69][71]). In ATT&CK they are G0065 Leviathan, which lists APT40 as an alias, and G0128 ZIRCONIUM, which lists APT31 (Confirmed [80]).

The court record

The FBI applied in the Southern District of Texas (Case No. 4:21mj755) for 14 days of remote access, beginning on or about 9 April 2021, to copy and then delete web shells on infected Exchange servers, without seizing other content; the filing was unsealed on 13 April (Confirmed [63]). The affidavit cites open-source reporting of at least 60,000 Microsoft customers compromised; the filing states it, but the number itself is secondary (Reported [63]). The Register reported that the FBI deleted web shells from hundreds of US servers by issuing a command through each shell, without patching them (Reported [48]; the DOJ release was not opened).

In July 2025 DOJ announced a nine-count indictment in the Southern District of Texas against Xu Zewei, arrested in Milan on 3 July 2025, and Zhang Yu, for intrusions between February 2020 and June 2021 including the HAFNIUM campaign. DOJ alleges they acted at the direction of officers of the MSS Shanghai

State Security Bureau and that Xu worked for Shanghai Powerock Network Co. Ltd. (Confirmed as allegations [64]). DOJ alleges exploitation began in late 2020, and that a law-firm mailbox search used terms including "MSS" and "HongKong" (Confirmed as allegations [64]). The FBI Cyber Division, quoted by DOJ, says HAFNIUM targeted over 60,000 US entities and victimized more than 12,700 (Confirmed as the FBI's statement [64]). Xu was extradited from Italy and appeared in US District Court in Houston on 27 April 2026; DOJ repeats the figure of more than 12,700 US organizations (Confirmed [65]). These are charges, not findings of guilt (Inferred).

What the numbers mean

Figure	Who counts	What it measures	Source
More than 400,000	DEVCORE's own survey	Internet-facing Exchange servers	[26]
Nearly 400,000; a bit more than 100,000; over 95%	Microsoft citing RiskIQ	In scope on 1 March; still vulnerable on 9 March; exposed versions for which an update existed by 11 March	[6]
Over 125,000	Expanse via Unit 42 (Reported)	Unpatched servers on 8 March	[32]
More than 5,000 in over 115 countries	ESET, called incomplete	Servers with web shells, 10 March	[31]
86,138 IPs, 101,045 hostnames, 79,352 web shell URLs	Shadowserver, honeypots excluded	Still vulnerable, and compromised, 16 to 23 March	[44]
About 1,500	Microsoft	Systems with Pydomer web shells	[10]
More than 92%	Microsoft	Known Exchange IPs patched or mitigated by 25 March	[10]
At least 30,000	KrebsOnSecurity, not independently verified	US organizations newly hacked, 5 March	[46] (Reported)
At least 60,000	Open-source reporting cited in the FBI affidavit	Microsoft customers compromised	[63] (Reported)
Tens of thousands	White House	Computers compromised before patches	[66]
Over a quarter of a million	UK government	Servers affected worldwide	[67]
Over 60,000 targeted, more than 12,700 victimized	FBI, quoted by DOJ in 2025	US entities	[64]

The counts measure different things (exposure, vulnerability, web shells, victims) on different dates and populations; none is a total of compromised organizations, and they should not be added or compared as if they were (Inferred).

Part 5: the vulnerability-management view

Exposure set the priority

Three of the four ProxyLogon CVEs scored 7.8, and each needed administrator credentials or another bug first (Confirmed [58][1]). Ranked by base score in isolation, the file-write bugs looked like ordinary post-authentication issues. Chained behind a 9.8 pre-authentication SSRF on an internet-facing port 443 listener, they were the payload of an unauthenticated RCE (Inferred from [1][4][57]). The same pattern repeated with ProxyShell, whose last link, CVE-2021-31207, was rated Moderate by Microsoft and 6.6 by NVD (Confirmed [14][60]).

The supported-CU problem

The March fixes installed only on specific cumulative updates, and Microsoft had to build extra SUs for older CUs from 8 March (Confirmed [5][3]). Those older-CU SUs addressed only the four CVEs (Confirmed [4]), and in August the Exchange team said servers that had taken them, or that ran only EOMT, were not protected against ProxyShell (Confirmed [17]). Microsoft later tied the Emergency Mitigation service directly to the March 2021 lesson that many customers were not on a supported CU (Confirmed [19]). Keeping current on CUs was a precondition for being patchable at all (Inferred).

Two clocks

Microsoft and CISA gave defenders a mitigation path (EOMT, the Defender auto-mitigation, blocking or limiting `/owa/` and `/ecp/` externally) and a remediation path (the update) (Confirmed [7][9][50]). By 11 March Microsoft had released updates covering more than 95% of exposed versions, and by 25 March more than 92% of known Exchange IPs were patched or mitigated (Confirmed [6][10]). Those headline figures merge the two clocks. A program that reports only one of them, or closes on mitigation, overstates its position (Inferred).

Patched is not clean

Microsoft's responder guidance says the updates do not evict an adversary already on the server (Confirmed [8]), and patching does not necessarily remove attacker access (Confirmed [10]). The 58-day window between the first observed exploitation and the fix (Inferred from [22][3]) meant that for some victims patch day was already too late. Any CVE exploited before its patch needs a look-back compromise assessment, which is what CISA's directive required (Confirmed [51]; Inferred for the general rule).

What the government required

ED 21-02 (3 March 2021) required federal agencies to triage, patch and report by 5 March, with forensic triage or disconnection; compromised servers stayed off the domain until rebuilt (Confirmed [51]). Supplemental Direction V1 (31 March) required the April updates by 16 April; V2 (13 April) required MSERT and Test-ProxyLogon scans and hardening by 28 June: updates within 48 hours, supported versions only, no Exchange account in Domain Admins, and 180 days of logs (Confirmed [51]). ED 21-02 was closed on 8 January 2026 and its actions moved under BOD 22-01 (Confirmed [51]).

Catalogs lag events

The KEV catalog shows 2021-11-03 for all seven ProxyLogon and ProxyShell CVEs because that was its first day, not because exploitation began then (Inferred from [56][57]). ProxyToken followed on 18 January 2022 and CVE-2021-31196 only on 21 August 2024, while CVE-2021-31195 is not in the catalog at all (Confirmed [61][62]). A KEV add date is a policy date; the first-exploitation date has to come from the vendor and incident record (Inferred).

The long tail

In August 2025 CISA's ED 25-02, for a different Exchange hybrid vulnerability (CVE-2025-53786), again mandated a Health Checker inventory and disconnection of servers not eligible for the April 2025 hotfix, including end-of-life servers (Confirmed [55]). Exchange 2016 and 2019 left support on 14 October 2025, with Exchange Online or Exchange Server Subscription Edition as the options (Confirmed [20]). The questions of 2021, which servers exist, which build they run and whether they can take a fix, were still the questions four years later (Inferred).

Part 6: the defender view

What to look for

Stage	Indicator	Source
CVE-2021-26855	HttpProxy logs with an empty `AuthenticatedUser` and `ServerInfo~` in `AnchorMailbox`; POSTs to `/owa/auth/Current/themes/resources/`	[1][22]
CVE-2021-26858	OABGenerator log entries with "Download failed and temporary file"	[1]
CVE-2021-27065	ECP log lines matching `Set-.+VirtualDirectory`, in particular `S:CMD=Set-OabVirtualDirectory.ExternalUrl=`; requests to `/ecp/DDI/DDIService.svc/SetObject`	[1][22][50]
CVE-2021-26857	MSExchange Unified Messaging application events with `InvalidCastException`	[1]
Web shells	Unexpected `.aspx` files under `C:\inetpub\wwwroot\aspnet_client` and the `Exchange`FrontEnd\HttpProxy\owa\auth` path; injected code in legitimate ASPX files; Defender detections `Exploit:Script/Exmann.A!dha` and `Trojan:JS/Chopper!dha`	[1][22][50]
Tools	The antSword user agent; Procdump or `rundll32 comsvcs.dll MiniDump` against lsass; 7-Zip or WinRAR archives; Exchange PowerShell mailbox exports	[50][1][22]
Processes	`w3wp.exe` spawning `cmd.exe`; `UMWorkerProcess.exe` writing ASPX files	[30]
Accounts	New domain accounts; removal of a user from Exchange Organization administrators	[22][30]

Microsoft published eight web shell SHA-256 hashes and web shell names and paths; Volexity published YARA rules and the 13 attacker IPs; CISA published China Chopper MARs (AR21-072A to G, AR21-084A and B, AR21-102A), YARA for SIMPLESEESHARP, SPORTSBALL and a reGeorg variant, and a DearCry MAR (Confirmed [1][22][50]). All ten of CISA's web shell MARs analyze China Chopper variants, and an eleventh covers DearCry (Confirmed [50]). Volexity found the original activity through network security monitoring of large outbound transfers from two customer Exchange servers (Confirmed [22]), a reminder that egress volume from a mail server is itself a signal (Inferred).

How to triage and remediate

CISA told defenders to look for compromise from at least 1 January 2021, run `Test-ProxyLogon.ps1`, use EOMT as an interim step, use the Volexity and CISA YARA rules, assume identity compromise if exploited, and block or limit `/owa/` and `/ecp/` externally (Confirmed [50]). Microsoft's responder guidance triages by finding type, explains the `Test-ProxyLogon` output, and gives web shell remediation steps: preserve evidence, disconnect, stop W3WP, remove the ASPX files, clear temporary ASP.NET files, run a full scan, update, and reset administrator credentials (Confirmed [8]).

What Exchange added afterwards

- **AMSI integration.** From the June 2021 CUs (2016 CU21, 2019 CU10), AMSI-capable antimalware can scan HTTP request content and block malicious requests with HTTP 400 before Exchange processes them (Confirmed [18]). Tying it to the 2021 attacks is this study's reading (Inferred).
- **Exchange Emergency Mitigation service.** From the September 2021 CU, a built-in EOMT running as a service, polling hourly for signed mitigations, on by default (Confirmed [19]).

Part 7: MITRE mappings

This Part binds the verified record to MITRE ATT&CK Enterprise v20.0, CWE, CAPEC and D3FEND, with every id checked against the live ATT&CK page or the library's data files on 3 November 2026. The event is Enterprise only; there is no ATT&CK for ICS or Mobile mapping. ATT&CK v20.0 has no campaign object for the 2021 Exchange mass exploitation, and the library's `data/attack/campaigns.jsonl` has no record matching exchange, proxylogon, proxyshell or hafnium (Confirmed [80]). Tactic names follow v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment; the one revoked id in the record (T1562.001) is shown under its successor from `data/attack/superseded_by.jsonl`.

ATT&CK Enterprise techniques: ProxyLogon and HAFNIUM-era intrusions

Id	Name	Tactic (v20.0)	Where it appears	Source	Grade
T1190	Exploit Public-Facing Application	Initial Access	ProxyLogon chain, SSRF from 3 Jan 2021 (Volexity); Mandiant clusters from Jan 2021; G0125 row	[22][30][72]	Confirmed
T1583.003	Virtual Private Server	Resource Development	HAFNIUM's leased US VPS (MSTIC, 2 Mar 2021); short-term VPS in AA21-200B (19 Jul 2021)	[1][53]	Confirmed
T1590	Gather Victim Network Information	Reconnaissance	Internal FQDN discovery (Volexity, 2 Mar 2021)	[22]	Confirmed
T1505.003	Web Shell	Persistence	SIMPLESEESHARP, SPORTSBALL, China Chopper, ASPXSPY (Volexity, 2 Mar 2021); `help.aspx`, `iisstart.aspx` (Mandiant, 4 Mar 2021); G0125 row	[22][30][72]	Confirmed
T1059.001	PowerShell	Execution	Exchange PowerShell snap-ins, Nishang (MSTIC, 2 Mar 2021)	[1]	Confirmed
T1059.003	Windows Command Shell	Execution	`cmd` through China Chopper (Rapid7, 23 Mar 2021); `w3wp.exe` spawning `cmd.exe` (Mandiant)	[34][30]	Confirmed
T1078.003	Local Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Files owned by NT AUTHORITY\SYSTEM, mapped by ATT&CK (Mandiant, 4 Mar 2021)	[30][72]	Confirmed
T1003.001	LSASS Memory	Credential Access	Procdump (MSTIC); `comsvcs.dll` MiniDump (Volexity)	[1][22]	Confirmed
T1218.011	Rundll32	Stealth	`rundll32 comsvcs.dll MiniDump` (Volexity)	[22]	Confirmed
T1003.003	NTDS	Credential Access	NTDS.DIT copied (Volexity)	[22]	Confirmed
T1136.002	Domain Account	Persistence	Domain accounts added (Volexity)	[22]	Confirmed
T1114.002	Remote Email Collection	Collection	EWS mailbox theft through the SSRF (Volexity, from 3 Jan 2021); PowerShell mailbox export (MSTIC)	[22][1]	Confirmed
T1560.001	Archive via Utility	Collection	7-Zip (MSTIC); WinRAR (Volexity)	[1][22]	Confirmed
T1567.002	Exfiltration to Cloud Storage	Exfiltration	MEGA, which Microsoft calls HAFNIUM's usual pattern rather than an observation in these intrusions; mapped on G0125	[1][72]	Confirmed on G0125; not observed in these intrusions
T1071.001	Web Protocols	Command and Control	Covenant C2 (MSTIC)	[1]	Confirmed

Id	Name	Tactic (v20.0)	Where it appears	Source	Grade
T1095	Non-Application Layer Protocol	Command and Control	Nishang and PowerCat (MSTIC)	[1]	Confirmed
T1105	Ingress Tool Transfer	Command and Control	Nishang and PowerCat (MSTIC); G0131 Tonto Team row citing ESET	[1][73]	Confirmed
T1033	System Owner/User Discovery	Discovery	`whoami` (Rapid7, 23 Mar 2021)	[34]	Confirmed
T1057	Process Discovery	Discovery	`tasklist` (Rapid7)	[34]	Confirmed
T1018	Remote System Discovery	Discovery	`nltest /dclist`, `net group "Domain Computers"` (Rapid7)	[34]	Confirmed
T1016	System Network Configuration Discovery	Discovery	`curl` to ipinfo.io (Rapid7)	[34]	Confirmed
T1016.001	Internet Connection Discovery	Discovery	Pings to 8.8.8.8 (Rapid7)	[34]	Confirmed
T1564.001	Hidden Files and Directories	Stealth	`attrib` hiding web shells (Rapid7; Talos Lemon Duck, May 2021)	[34][40]	Confirmed

In all, 31 technique rows on ATT&CK's G0125 page cite the 2021 MSTIC, Volexity, Mandiant or Rapid7 reports; the table lists those the opened record ties to a specific behaviour (Confirmed [72]).

ATT&CK Enterprise techniques: other actors on the same bugs

Id	Name	Tactic (v20.0)	Where it appears	Source	Grade
T1574.001	DLL	Stealth, Execution	Calypso PlugX via DLL search-order hijacking (ESET, 10 Mar 2021); G0131 row	[31][73]	Confirmed
T1003.002	Security Account Manager	Credential Access	DearCry batch file copying SAM and hives (Microsoft, 25 Mar 2021)	[10]	Inferred mapping
T1486	Data Encrypted for Impact	Impact	DearCry (Microsoft, Sophos), Black Kingdom (Sophos), March 2021; listed by id in AA21-321A (17 Nov 2021)	[10][36][37][54]	Inferred for March; Confirmed in AA21-321A
T1496.001	Compute Hijacking	Impact	XMRig and Lemon Duck miners (Microsoft, 25 Mar 2021; Talos, May 2021)	[10][40]	Inferred mapping
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	Lemon Duck (Microsoft); Sapphire Pigeon `Winnet` task (Red Canary); listed in AA21-321A	[10][35][54]	Inferred for March; Confirmed in AA21-321A
T1546.003	Windows Management Instrumentation Event Subscription	Privilege Escalation, Persistence	Lemon Duck WMI persistence (Microsoft)	[10]	Inferred mapping
T1685	Disable or Modify Tools (was T1562.001)	Defense Impairment	Lemon Duck disabling Defender real-time monitoring (Microsoft)	[10]	Inferred mapping
T1071.004	DNS	Command and Control	Cobalt Strike DNS beacons on Lemon Duck infrastructure (Talos)	[40]	Confirmed
T1136.001	Local Account	Persistence	Local user `netcat` (Talos); local admin accounts (Microsoft); listed in AA21-321A	[40][10][54]	Confirmed
T1021.001	Remote Desktop Protocol	Lateral Movement	RDP enabled on Lemon Duck hosts (Talos)	[40]	Inferred mapping

The DearCry, Lemon Duck and miner rows are not HAFNIUM activity (Confirmed [10]).

ATT&CK Enterprise techniques: ProxyShell era

Id	Name	Tactic (v20.0)	Where it appears	Source	Grade
T1190	Exploit Public-Facing Application	Initial Access	Iranian actors exploiting CVE-2021-34473 (AA21-321A); G0059, G0046, G1043, G1003 rows	[54][75]	Confirmed
T1595.002	Vulnerability Scanning	Reconnaissance	G0059 Magic Hound ProxyShell row	[75]	Confirmed
T1070.003	Clear Command History	Stealth	G0059 Magic Hound ProxyShell row	[75]	Confirmed
T1134.003	Make and Impersonate Token	Stealth, Privilege Escalation	G1043 BlackByte row	[75]	Confirmed
T1588.001	Malware	Resource Development	AA21-321A	[54]	Confirmed
T1588.002	Tool	Resource Development	AA21-321A	[54]	Confirmed

AA21-321A's table also lists T1190, T1053.005, T1136.001, T1136.002, T1560.001 and T1486 (Confirmed [54]); G0059 and G1043 also carry T1114.002 and T1505.003 rows respectively (Confirmed [75]).

Inferred and demonstration-only mappings

Id	Name	Tactic (v20.0)	Basis	Source	Grade
T1569.002	Service Execution	Execution	PsExec lateral movement (Volexity)	[22]	Inferred
T1090	Proxy	Command and Control	Web shells used for proxying (Volexity); reGeorg variant (CISA YARA, ESET)	[22][50][31]	Inferred
T1087.003	Email Account	Discovery	Offline address book download (MSTIC)	[1][79]	Inferred
T1531	Account Access Removal	Impact	Removal of a user from Exchange Organization administrators in at least two cases (Mandiant)	[30]	Inferred
T1114.003	Email Forwarding Rule	Collection	ProxyToken lets an attacker set a forwarding rule on any mailbox	[29]	Demonstrated
T1539	Steal Web Session Cookie	Credential Access	ProxyOracle recovers the password from the `cadata` cookie	[25]	Demonstrated

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to the event	Source
HAFNIUM	G0125	Aliases Operation Exchange Marauder and Silk Typhoon; ATT&CK page modified 31 July 2026 under v20	[72]
Threat Group-3390 (LuckyMouse, APT27)	G0027	T1190 row naming the four CVEs, citing Trend Micro 2021 (not opened); ESET, 1 Mar 2021	[75][31]
Tonto Team	G0131	Four rows citing ESET (T1505.003, T1059.001, T1574.001, T1105)	[73]
APT41	G0096	T1190 row naming CVE-2021-26855; home study: APT41 public record	[75]
Winnti Group	G0044	ESET sighting; ATT&CK page has no Exchange 2021 row, so not mapped	[74][31]
BRONZE BUTLER (Tick)	G0060	ESET sighting; ATT&CK page has no Exchange 2021 row, so not mapped	[74][31]
ToddyCat	G1022	Later ProxyLogon T1190 row, citing Kaspersky 2022	[75]
Magic Hound	G0059	ProxyShell rows (T1595.002, T1114.002, T1070.003)	[75]
FIN7	G0046	CVE-2021-31207 row	[75]
BlackByte	G1043	ProxyLogon and ProxyShell rows (T1505.003, T1134.003)	[75]
Ember Bear	G1003	ProxyShell row	[75]
Leviathan (APT40), ZIRCONIUM (APT31)	G0065, G0128	Separate 19 July 2021 attributions, not the Exchange campaign	[67][71][80]
China Chopper	S0020	ATT&CK lists HAFNIUM as a user; all ten CISA web shell MARs; library page maps 10 techniques	[76][50]
ASPXSpy	S0073	Volexity's ASPXSPY; HAFNIUM software in ATT&CK	[22][72]
Covenant	S1155	HAFNIUM C2 (MSTIC)	[1][72]
PsExec	S0029	Volexity lateral movement	[22][72]
Impacket, Tarrask	S0357, S1011	Listed for HAFNIUM from references published in 2022; not the 2021 event	[72]
Mimikatz	S0002	Calypso and Winnti Group (ESET)	[31]
PlugX	S0013	Calypso and Winnti Group (ESET)	[31]
ShadowPad	S0596	Tonto Team and unattributed activity (ESET)	[31]
Bisonal	S0268	Tonto Team variant (ESET)	[31]
NBTscan	S0590	LuckyMouse (ESET)	[31]
SysUpdate	S0663	LuckyMouse attempt (ESET)	[31]

Object	Id and library page	Tie to the event	Source
reGeorg	S1187	LuckyMouse variant (ESET); CISA YARA; no Exchange row in ATT&CK, so linked as a tool only	[77][31][50]
Cobalt Strike	S0154	UNC2643 BEACON (Mandiant); "Opera" cluster (ESET); DearCry (Microsoft); Lemon Duck DNS beacons (Talos)	[30][31][10][40]
Winnti for Windows	S0141	ESET's "Winnti loader"; pairing the loader with S0141 is this study's reading (Inferred)	[31]
SolarWinds Compromise	C0024	Its T1190 row records APT29 exploiting CVE-2020-0688 against the ECP; a different event, home in the SolarWinds and SUNBURST study	[78]

SIMPLESEESHARP, SPORTSBALL, DearCry or DoejoCrypt, Black Kingdom or Pydomer, Lemon Duck, Nishang and PowerCat have no ATT&CK software object in the library's data and are left unlinked (Confirmed [80]).

CWE and CAPEC

Weakness	CVEs (NVD)	CAPEC in the library	Source
CWE-918 Server-Side Request Forgery	CVE-2021-26855, CVE-2021-34473	CAPEC-664 Server Side Request Forgery	[57][60][80]
CWE-502 Deserialization of Untrusted Data	CVE-2021-26857	CAPEC-586 Object Injection	[58][80]
CWE-22 Path Traversal	CVE-2021-27065	CAPEC-126 Path Traversal	[59][80]
CWE-434 Unrestricted Upload of File with Dangerous Type	CVE-2021-31207	CAPEC-1, which lists CWE-434	[60][80]
CWE-290 Authentication Bypass by Spoofing	CVE-2021-31195 (CNA assignment only)	Not mapped here	[62]
NVD-CWE-noinfo	CVE-2021-26858, CVE-2021-34523, CVE-2021-33766, CVE-2021-31196	None	[58][60][61][62]

CAPEC-650 Upload a Web Shell to a Web Server maps to T1505.003 in the library; it ties to this event through the web shell technique, not through any CVE's CWE (Inferred from [80]). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

Countermeasure	Id	Library mapping to this study's techniques	Guidance it matches	Source
Inbound Traffic Filtering	D3-ITF	T1190	Restricting untrusted connections to port 443, blocking or limiting `/owa/` and `/ecp/`	[80][4][50]
Network Traffic Signature Analysis	D3-NTSA	T1190	Network detection of the exploit requests (Inferred pairing)	[80]
File Integrity Monitoring	D3-FIM	T1505.003	Unexpected ASPX files and injected code in legitimate ASPX files	[80][1][22]
File Creation Analysis	D3-FCA	Library page exists	`UMWorkerProcess.exe` or `w3wp.exe` writing ASPX files (Inferred pairing)	[80][30]
Process Spawn Analysis	D3-PSA	T1505.003	`w3wp.exe` spawning `cmd.exe`	[80][30]
Process Lineage Analysis	D3-PLA	T1505.003	Shells descending from the IIS worker	[80][30]
Executable Allowlisting	D3-EAL	T1505.003	Limiting what the web tier can run (Inferred pairing)	[80]
File Eviction	D3-FEV	T1505.003	Removing ASPX web shells; the FBI's web shell deletion	[80][8][63]
Restore File	D3-RF	T1505.003	Restoring legitimate ASPX files with injected code (Inferred pairing)	[80][22]
Credential Rotation and Credential Revocation	D3-CRO, D3-CR	T1003.003	Resetting administrator credentials; assuming identity compromise	[80][8][50]
Credential Hardening	D3-CH	Library page exists	No Exchange account in Domain Admins (ED 21-02 V2) (Inferred pairing)	[80][51]
Email Removal	D3-ER	T1114.002	Not a remediation either source names (Inferred pairing)	[80]
Outbound Traffic Filtering	D3-OTF	T1567.002	Large outbound transfers that led Volexity to the activity (Inferred pairing)	[80][22]
Software Update	D3-SU	Not mapped to T1190 in the library	The security updates and staying on a supported CU (Inferred pairing)	[80][3]

T1059.001 has no D3FEND rows in the library (Confirmed [80]).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/exchange-marauder-2021.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of its tie to the 2021 Exchange exploitation: 100 where the ProxyLogon or HAFNIUM-era record or a government advisory ties the technique to the event, 75 for follow-on actors on the same bugs and the ProxyShell era, and 40 for the Inferred and demonstration-only mappings. Two exceptions: T1567.002 scores 75 because Microsoft describes MEGA exfiltration as HAFNIUM's usual pattern rather than an observation in these intrusions, and T1486 and T1053.005 score 75 because AA21-321A lists them for the ProxyShell era. Each entry's comment names the source numbers above.

Cross-cutting themes

- **The edge server is the identity system.** ProxyLogon worked because the front end vouched for requests with the machine account's own Kerberos ticket (Demonstrated [24]). Mail theft through EWS bypassed two-factor authentication (Confirmed [22]). An on-premises application that proxies on behalf of users is part of the identity perimeter (Inferred). See Threat Actors for the actors who exploit it.
- **Disclosure does not start the clock.** Exploitation preceded the report to the vendor by two days, and ESET wrote in March 2021 that the source of the pre-patch exploit distribution remained unclear (Confirmed [22][23][31]). Defenders should treat the vendor's patch date as a midpoint, not a start (Inferred).
- **A fix is a map for the next attacker.** Microsoft's 5 March update and ESET's timeline show exploitation widening after 2 March, from a handful of pre-patch groups to more than ten, then to ransomware and miners (Confirmed [1][31][10]; the causal reading is Inferred).
- **Interim mitigations are partial by design.** EOMT and the Defender mitigation addressed CVE-2021-26855 alone; the Exchange team later said EOMT-only servers were not protected against ProxyShell (Confirmed [7][9][17]).
- **Research keeps paying out on the same surface.** DEVCORE's eight bugs on the Client Access Service produced three named chains in a year (Confirmed [26]). When a product's architecture yields one critical chain, budget for the next (Inferred).
- **Attribution moves slowly and carefully.** Vendor naming on day one, coordinated government statements in July, a charging document in 2025 and an extradition in 2026, each with its own confidence language (Confirmed [1][66][64][65]). A study that strips those hedges overstates the record.

What is overstated and what is understated

- **Overstated: single victim counts.** Figures from 30,000 to a quarter of a million servers measure different things, and the 30,000 and 60,000 figures rest on press and open-source reporting (Reported [46][63]; Confirmed [67]). The most specific official figure is the FBI's more than 12,700 US victims, quoted in DOJ's 2025 announcement (Confirmed [64]).
- **Overstated: one actor.** "HAFNIUM hacked Exchange" is true for the zero-day phase and incomplete for the rest: ESET names other groups, Mandiant tracks uncategorized clusters it did not attribute, and Red Canary says none of its clusters overlap significantly with HAFNIUM (Confirmed [31][30][35]).
- **Understated: the post-auth bugs.** The 7.8 file-write bugs remained reachable with stolen administrator credentials after the SSRF was mitigated (Confirmed [1]; Inferred for the risk).
- **Understated: web shells after patching.** Tens of thousands of web shell URLs were still live three weeks after the fix (Confirmed [44]), and the US government judged the problem serious enough to remove shells itself under a warrant (Confirmed [63]).

Sources

All sources were opened on 3 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. The URL for source 69 is printed as text rather than a link because the EEAS site answers automated link checkers with HTTP 403; copy it into a browser to read it.

#	Source	URL	Opened	Grade
1	Microsoft Threat Intelligence, HAFNIUM targeting Exchange Servers with 0-day exploits, 2 Mar 2021 (updated 5 Mar)	microsoft.com/en-us/security/blog/2021/03/02/hafnium-targeting-exchange-servers/	2026-11-03	Confirmed
2	Microsoft On the Issues, New nation-state cyberattacks, 2 Mar 2021	blogs.microsoft.com/on-the-issues/2021/03/02/new-nation-state-cyberattacks/	2026-11-03	Confirmed
3	MSRC, Multiple Security Updates Released for Exchange Server, Mar 2021	microsoft.com/en-us/msrc/blog/2021/03/multiple-security-updates-released-for-exchange-server	2026-11-03	Confirmed
4	MSRC Security Update Guide, CVE-2021-26855	msrc.microsoft.com/update-guide/vulnerability/CVE-2021-26855	2026-11-03	Confirmed
5	Exchange Team, Released: March 2021 Exchange Server Security Updates	techcommunity.microsoft.com/t5/exchange-team-blog/released-march-2021-exchange-server-security-updates/ba-p/2175901	2026-11-03	Confirmed
6	Microsoft, Protecting on-premises Exchange Servers against recent attacks, 12 Mar 2021	microsoft.com/en-us/security/blog/2021/03/12/protecting-on-premises-exchange-servers-against-recent-attacks/	2026-11-03	Confirmed
7	MSRC, One-Click Microsoft Exchange On-Premises Mitigation Tool, Mar 2021	microsoft.com/en-us/msrc/blog/2021/03/one-click-microsoft-exchange-on-premises-mitigation-tool-march-2021	2026-11-03	Confirmed
8	MSRC, Guidance for responders: investigating and remediating on-premises Exchange Server vulnerabilities, 16 Mar 2021	microsoft.com/en-us/msrc/blog/2021/03/guidance-for-responders-investigating-and-remediating-on-premises-exchange-server-vulnerabilities	2026-11-03	Confirmed
9	Microsoft, Automatic on-premises Exchange server mitigation now in Microsoft Defender Antivirus, 18 Mar 2021	microsoft.com/en-us/security/blog/2021/03/18/automatic-on-premises-exchange-server-mitigation-now-in-microsoft-defender-antivirus/	2026-11-03	Confirmed
10	Microsoft, Analyzing attacks taking advantage of the Exchange Server vulnerabilities, 25 Mar 2021	microsoft.com/en-us/security/blog/2021/03/25/analyzing-attacks-taking-advantage-of-the-exchange-server-vulnerabilities/	2026-11-03	Confirmed
11	Microsoft Threat Intelligence, Silk Typhoon targeting IT supply chain, 5 Mar 2025	microsoft.com/en-us/security/blog/2025/03/05/silk-typhoon-targeting-it-supply-chain/	2026-11-03	Confirmed
12	Exchange Team, Released: April 2021 Exchange Server Security Updates	techcommunity.microsoft.com/t5/exchange-team-blog/released-april-2021-exchange-server-security-updates/ba-p/2254617	2026-11-03	Confirmed
13	MSRC Security Update Guide, CVE-2021-34473	msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34473	2026-11-03	Confirmed
14	MSRC Security Update Guide, CVE-2021-31207	msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31207	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
15	MSRC Security Update Guide, CVE-2021-33766	msrc.microsoft.com/update-guide/vulnerability/CVE-2021-33766	2026-11-03	Confirmed
16	MSRC Security Update Guide, CVE-2021-31196 (and CVE-2021-31195)	msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31196	2026-11-03	Confirmed
17	Exchange Team, ProxyShell vulnerabilities and your Exchange Server, 25 Aug 2021	techcommunity.microsoft.com/blog/exchange/proxyshell-vulnerabilities-and-your-exchange-server/2684705	2026-11-03	Confirmed
18	Exchange Team, More about AMSI integration with Exchange Server, 22 Jul 2021	techcommunity.microsoft.com/blog/exchange/more-about-amsi-integration-with-exchange-server/2572371	2026-11-03	Confirmed
19	Exchange Team, New security feature in September 2021 Cumulative Update for Exchange Server	techcommunity.microsoft.com/blog/exchange/new-security-feature-in-september-2021-cumulative-update-for-exchange-server/2783155	2026-11-03	Confirmed
20	Exchange Team, Support for Exchange Server 2016 and Exchange Server 2019 ends today, 14 Oct 2025	techcommunity.microsoft.com/blog/exchange/support-for-exchange-server-2016-and-exchange-server-2019-ends-today/4461192	2026-11-03	Confirmed
21	Microsoft, CSS-Exchange repository, Security folder	github.com/microsoft/CSS-Exchange/tree/main/Security	2026-11-03	Confirmed
22	Volexity, "Operation Exchange Marauder" post on active exploitation of Exchange zero-days, 2 Mar 2021 (updated 8 Mar)	volexity.com/blog/2021/03/02/active-exploitation-of-microsoft-exchange-zero-day-vulnerabilities/	2026-11-03	Confirmed
23	DEVCORE, ProxyLogon site and timeline	proxylogon.com	2026-11-03	Confirmed
24	DEVCORE, A New Attack Surface on MS Exchange Part 1: ProxyLogon, 6 Aug 2021	devco.re/blog/2021/08/06/a-new-attack-surface-on-MS-exchange-part-1-ProxyLogon/	2026-11-03	Demonstrated
25	DEVCORE, A New Attack Surface on MS Exchange Part 2: ProxyOracle	devco.re/blog/2021/08/06/a-new-attack-surface-on-MS-exchange-part-2-ProxyOracle/	2026-11-03	Demonstrated
26	Orange Tsai (DEVCORE), ProxyLogon Is Just the Tip of the Iceberg, Black Hat USA 2021 handout	i.blackhat.com/USA21/Wednesday-Handouts/us-21-ProxyLogon-Is-Just-The-Tip-Of-The-Iceberg-A-New-Attack-Surface-On-Microsoft-Exchange-Server.pdf	2026-11-03	Confirmed
27	Zero Day Initiative, Pwn2Own 2021 schedule and live results	zerodayinitiative.com/blog/2021/4/2/pwn2own-2021-schedule-and-live-results	2026-11-03	Demonstrated
28	Zero Day Initiative, From Pwn2Own 2021: A New Attack Surface on Microsoft Exchange, ProxyShell, 17 Aug 2021	zerodayinitiative.com/blog/2021/8/17/from-pwn2own-2021-a-new-attack-surface-on-microsoft-exchange-proxyshell	2026-11-03	Demonstrated
29	Zero Day Initiative, ProxyToken: An Authentication Bypass in Microsoft Exchange Server, 30 Aug 2021	zerodayinitiative.com/blog/2021/8/30/proxytoken-an-authentication-bypass-in-microsoft-exchange-server	2026-11-03	Demonstrated
30	Mandiant (Google Cloud), Detection and Response to Exploitation of Microsoft Exchange Zero-Day Vulnerabilities, 4 Mar 2021	cloud.google.com/blog/topics/threat-intelligence/detection-response-to-exploitation-of-microsoft-exchange-zero-day-vulnerabilities	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
31	ESET WeLiveSecurity, Exchange servers under siege from at least 10 APT groups, 10 Mar 2021	welivesecurity.com/2021/03/10/exchange-servers-under-siege-10-apt-groups/	2026-11-03	Confirmed
32	Palo Alto Networks Unit 42, Microsoft Exchange Server attack timeline	unit42.paloaltonetworks.com/microsoft-exchange-server-attack-timeline/	2026-11-03	Confirmed for its own data; Reported where it relays others
33	Palo Alto Networks Unit 42, DearCry ransomware	unit42.paloaltonetworks.com/dearcry-ransomware/	2026-11-03	Confirmed
34	Rapid7, Defending against the zero day: analyzing attacker behavior post-exploitation of Microsoft Exchange, 23 Mar 2021	rapid7.com/blog/post/2021/03/23/defending-against-the-zero-day-analyzing-attacker-behavior-post-exploitation-of-microsoft-exchange/	2026-11-03	Confirmed
35	Red Canary, Microsoft Exchange attacks analysis (read on the copy the redcanary.com URL redirects to)	zscaler.com/blogs/cybersecurity-best-practices/microsoft-exchange-attacks	2026-11-03	Confirmed
36	Sophos, DearCry ransomware attacks exploit Exchange Server vulnerabilities	sophos.com/en-us/blog/dearcry-ransomware-attacks-exploit-exchange-server-vulnerabilities/ (plain text: the host fails automated link checks)	2026-11-03	Confirmed
37	Sophos, Black Kingdom ransomware	sophos.com/en-us/blog/black-kingdom/ (plain text: the host fails automated link checks)	2026-11-03	Confirmed
38	Sophos, Epsilon Red (page undated; year from coverage)	sophos.com/en-us/blog/epsilonred (plain text: the host fails automated link checks)	2026-11-03	Confirmed
39	Sophos, Conti affiliates use ProxyShell Exchange exploit in ransomware attacks (page undated)	sophos.com/en-us/blog/conti-affiliates-use-proxyshell-exchange-exploit-in-ransomware-attacks (plain text: the host fails automated link checks)	2026-11-03	Confirmed
40	Cisco Talos, Lemon Duck spreads its wings, May 2021	blog.talosintelligence.com/2021/05/lemon-duck-spreads-wings.html	2026-11-03	Confirmed
41	Cisco Talos, Babuk exploits Exchange	blog.talosintelligence.com/babuk-exploits-exchange/	2026-11-03	Confirmed
42	Symantec (security.com), LockFile: Ransomware uses PetitPotam exploit, 20 Aug 2021	security.com/threat-intelligence/lockfile-ransomware-new-petitpotam-windows	2026-11-03	Confirmed
43	Huntress, Rapid response: Microsoft Exchange servers still vulnerable to ProxyShell exploit, Aug 2021	huntress.com/blog/rapid-response-microsoft-exchange-servers-still-vulnerable-to-proxyshell-exploit	2026-11-03	Confirmed
44	The Shadowserver Foundation, Exchange scanning results, Mar 2021	shadowserver.org/hp-rewrite/5b7e8109d86544dea0a149ab5f59b6da	2026-11-03	Confirmed
45	Tenable, CVE-2021-28480 to CVE-2021-28483: four critical Microsoft Exchange vulnerabilities, Apr 2021	tenable.com/blog/cve-2021-28480-cve-2021-28481-cve-2021-28482-cve-2021-28483-four-critical-microsoft-exchange	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
46	KrebsOnSecurity, At least 30,000 U.S. organizations newly hacked via holes in Microsoft's email software, 5 Mar 2021	krebsonsecurity.com/2021/03/at-least-30000-u-s-organizations-newly-hacked-via-holes-in-microsofts-email-software/	2026-11-03	Reported
47	BleepingComputer, Ransomware now attacks Microsoft Exchange servers with ProxyLogon exploits, 11 Mar 2021	bleepingcomputer.com/news/security/ransomware-now-attacks-microsoft-exchange-servers-with-proxylogon-exploits/	2026-11-03	Reported
48	The Register, FBI Exchange web shell removal, 14 Apr 2021	theregister.com/2021/04/14/fbi_exchange_server/	2026-11-03	Reported
49	The Record, China accuses US of launching cyberattacks, denies Microsoft Exchange hack, Jul 2021	therecord.media/china-accuses-us-of-launching-cyberattacks-denies-microsoft-exchange-hack/	2026-11-03	Reported
50	CISA, Alert AA21-062A, Mitigate Microsoft Exchange Server Vulnerabilities (revision history through 19 Jul 2021)	cisa.gov/news-events/cybersecurity-advisories/aa21-062a	2026-11-03	Confirmed
51	CISA, Emergency Directive 21-02 and supplemental directions (closed)	cisa.gov/news-events/directives/ed-21-02-mitigate-microsoft-exchange-premises-product-vulnerabilities-closed and cisa.gov/news-events/directives/ed-21-02-mitigate-microsoft-exchange-premises-product-vulnerabilities	2026-11-03	Confirmed
52	CISA, Urgent: Protect Against Active Exploitation of ProxyShell Vulnerabilities, 21 Aug 2021	cisa.gov/news-events/alerts/2021/08/21/urgent-protect-against-active-exploitation-proxyshell-vulnerabilities	2026-11-03	Confirmed
53	NSA, CISA and FBI, AA21-200B, Chinese State-Sponsored Cyber Operations: Observed TTPs, 19 Jul 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-200b	2026-11-03	Confirmed
54	FBI, CISA, ACSC and NCSC, AA21-321A, Iranian government-sponsored APT actors, 17 Nov 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-321a	2026-11-03	Confirmed
55	CISA, Emergency Directive 25-02, Mitigate Microsoft Exchange Vulnerability, 7 Aug 2025	cisa.gov/news-events/directives/ed-25-02-mitigate-microsoft-exchange-vulnerability	2026-11-03	Confirmed
56	CISA, Known Exploited Vulnerabilities catalog JSON feed, catalogVersion 2026.11.03	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-03	Confirmed
57	NVD, CVE-2021-26855 (API record)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2021-26855	2026-11-03	Confirmed
58	NVD, CVE-2021-26857 (with the CVE-2021-26858 and CVE-2021-27065 records)	nvd.nist.gov/vuln/detail/CVE-2021-26857	2026-11-03	Confirmed
59	NVD, CVE-2021-27065 (API record)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2021-27065	2026-11-03	Confirmed
60	NVD, CVE-2021-34473 (with the CVE-2021-34523 and CVE-2021-31207 records)	nvd.nist.gov/vuln/detail/CVE-2021-34473	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
61	NVD, CVE-2021-33766	nvd.nist.gov/vuln/detail/CVE-2021-33766	2026-11-03	Confirmed
62	NVD, CVE-2021-31196 (with the CVE-2021-31195 record)	nvd.nist.gov/vuln/detail/CVE-2021-31196	2026-11-03	Confirmed
63	US Department of Justice, FBI application and affidavit, S.D. Texas Case No. 4:21mj755, unsealed 13 Apr 2021	justice.gov/media/1136141/dl	2026-11-03	Confirmed (the 60,000 figure inside it: Reported)
64	US Department of Justice, Justice Department announces arrest of prolific Chinese state-sponsored contract hacker, 8 Jul 2025	justice.gov/opa/pr/justice-department-announces-arrest-prolific-chinese-state-sponsored-contract-hacker	2026-11-03	Confirmed (allegations)
65	US Department of Justice, Prolific Chinese state-sponsored contract hacker extradited from Italy, Apr 2026	justice.gov/opa/pr/prolific-chinese-state-sponsored-contract-hacker-extradited-italy	2026-11-03	Confirmed
66	The White House (archived), The United States, joined by allies and partners, attributes malicious cyber activity to the PRC, 19 Jul 2021	bidenwhitehouse.archives.gov/briefing-room/statements-releases/2021/07/19/...	2026-11-03	Confirmed
67	UK Government (FCDO), UK and allies hold Chinese state responsible for a pervasive pattern of hacking, 19 Jul 2021	gov.uk/government/news/uk-and-allies-hold-chinese-state-responsible-for-a-pervasive-pattern-of-hacking	2026-11-03	Confirmed
68	UK NCSC, UK and allies hold Chinese state responsible for pervasive pattern of hacking, 19 Jul 2021	ncsc.gov.uk/news/uk-allies-hold-chinese-state-responsible-for-pervasive-pattern-of-hacking	2026-11-03	Confirmed
69	EU High Representative, declaration urging Chinese authorities to act, 19 Jul 2021 (read on the EEAS delegation copy; the Council page refused automated requests)	`https://www.eeas.europa.eu/delegations/bolivia/china-declaraci%C3%B3n-del-alto-representante-nombre-de-la-uni%C3%B3n-europea-instando-las-autoridades-chinas_und_en`	2026-11-03	Confirmed
70	NATO North Atlantic Council, statement in solidarity with those affected by the Microsoft Exchange compromise, 19 Jul 2021	nato.int/cps/en/natohq/news_185863.htm	2026-11-03	Confirmed
71	Global Affairs Canada, Statement on China's cyber campaigns, 19 Jul 2021	canada.ca/en/global-affairs/news/2021/07/statement-on-chinas-cyber-campaigns.html (plain text: the host fails automated link checks)	2026-11-03	Confirmed
72	MITRE ATT&CK v20, G0125 HAFNIUM	attack.mitre.org/groups/G0125/	2026-11-03	Confirmed
73	MITRE ATT&CK v20, G0131 Tonto Team	attack.mitre.org/groups/G0131/	2026-11-03	Confirmed
74	MITRE ATT&CK v20, G0060 BRONZE BUTLER and G0044 Winnti Group	attack.mitre.org/groups/G0060/ (and the same path for G0044)	2026-11-03	Confirmed
75	MITRE ATT&CK v20, later ProxyLogon and ProxyShell rows: G0059, G0027, G0096, G1022, G0046, G1043, G1003	attack.mitre.org/groups/G0059/ (and the same path for each id)	2026-11-03	Confirmed
76	MITRE ATT&CK v20, S0020 China Chopper	attack.mitre.org/software/S0020/	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
77	MITRE ATT&CK v20, S1187 reGeorg	attack.mitre.org/software/S1187/	2026-11-03	Confirmed
78	MITRE ATT&CK v20, T1190 Exploit Public-Facing Application (C0024 row)	attack.mitre.org/techniques/T1190/	2026-11-03	Confirmed
79	MITRE ATT&CK v20, T1087.003 Email Account	attack.mitre.org/techniques/T1087/003/	2026-11-03	Confirmed
80	TeamStarWolf library data: `data/attack/` (technique profiles, campaigns, software, superseded_by, technique_to_d3fend, d3fend_countermeasures), `data/weaknesses/`, the `mitre/` tree and `mitre/groups/G0125.md`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-03	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Detection Rules Reference
- Case studies: APT41 public record study, Log4Shell study, SolarWinds and SUNBURST study
- Groups: G0125 HAFNIUM, G0027 Threat Group-3390, G0131 Tonto Team, G0096 APT41, G0044 Winnti Group, G0060 BRONZE BUTLER, G1022 ToddyCat, G0059 Magic Hound, G0046 FIN7, G1043 BlackByte, G1003 Ember Bear, G0065 Leviathan, G0128 ZIRCONIUM
- Campaign: C0024 SolarWinds Compromise
- Software: S0020 China Chopper, S0073 ASPXSpy, S1155 Covenant, S0029 PsExec, S0002 Mimikatz, S0013 PlugX, S0596 ShadowPad, S0268 Bisonal, S0590 NBTscan, S0663 SysUpdate, S1187 reGeorg, S0154 Cobalt Strike, S0141 Winnti for Windows, S0357 Impacket, S1011 Tarrask
- Techniques: T1190 Exploit Public-Facing Application, T1505.003 Web Shell, T1114.002 Remote Email Collection, T1003.001 LSASS Memory, T1003.003 NTDS, T1560.001 Archive via Utility, T1486 Data Encrypted for Impact
- CAPEC: CAPEC-664, CAPEC-586, CAPEC-126, CAPEC-1, CAPEC-650
- Navigator layers, including this study's layer, exchange-marauder-2021.json